

支付前置风控与 Web 反欺诈检测服务选型

导出自 Claude Code 会话 · 日期 2026-06-26 主线:browserleaks 能否做成 JSON → 自带风控策略的 web 端检测服务横评 → 自建 payment checkout 前置风控选型 → 价格对比 + 同一用户重复验证评估 说明:本文为会话内容的结构化整理(非原始逐字记录),结论均经多源检索 + 对抗式验证。文末附「相关记忆」背景。

0. 速读结论(TL;DR)

- **browserleaks 没有官方 API**,但唯一可直调的 JSON 接口是 `tls.browserleaks.com/json` (返回 JA3/JA3N/JA4/Akamai 指纹,反映调用方自身 TLS 握手)。其余测试要么是服务端渲染 HTML(可爬),要么是浏览器里 JS 现算(需自建采集或跑无头浏览器)。
- **"自带风控策略"** 指服务自带预置规则/策略引擎、直接吐 `通过/审核/拒绝` 决策(full-decision-engine),区别于只给原始信号要你自己定阈值的(score-only)。
- **自建 payment checkout 前置风控,首选 SEON**:输出三态决策、PSP 无关、数据增强强、自带预置+可改规则、接入轻、定价透明有免费档、PCI 友好。
- **价格本质看"计价模型"**:按次/按笔(SEON/IPQS/Fingerprint)随交易笔数累加;按 GMV 抽成(Riskified/Forter)或企业套餐(Sift/Sardine)重复评估不额外计费;Stripe Radar 走标准价基本免费但锁 Stripe。
- **同一用户重复验证**:风险评分要**逐笔做**(风险是交易级,ATO/盗卡/velocity);但用户可见验证(3DS/OTP/验证码)**不要反复打扰良性用户**——用设备指纹 + trust list + 风险自适应,只在异常时升级。

1. browserleaks 数据能否做成返回 JSON

1.1 站点本身(实测 2026-06-18)

- **无官方公开 API**; `api.browserleaks.io` 是第三方仿站(`residentialproxies` ,复用 CreepJS 代码),非真站。
- **唯一可直调 JSON**: `https://tls.browserleaks.com/json` —— 无鉴权、无 Cloudflare、`curl` 直接 200(连 UA 都不校验)。返回: `user_agent`, `ja4`, `ja4_r`, `ja4_o`, `ja4_ro`, `ja3_hash`, `ja3_text`, `ja3n_hash`, `ja3n_text`, `akamai_hash`, `akamai_text` 。反映**调用方自己的** TLS 握手。
- `robots.txt` = `Allow: /` + `Crawl-delay: 60` ,无 ToS 合同。
- `/ip` 是服务端渲染 HTML(IP/geo/ASN/headers 可爬); `canvas/webgl/fonts/javascript/webrtc/dns/geo` 全是浏览器里 JS 现算,**无服务端 JSON 可取**。

1.2 三种把数据做成 JSON 的路子

方式	覆盖	代价
A. 直调 <code>tls.browerleaks.com/json</code>	只有 TLS/JA3/JA4/Akamai	零成本
B. 无头浏览器跑 <code>browerleaks</code> 页面	几乎全套	慢、脆、要解析 DOM
C. 自建采集服务(重写测试)	全套 + 可控可扩展	工作量大,但这才是正解

1.3 自建:前端可采 vs 后端必须

● **纯前端 JS 可采:**Canvas、WebGL(`WEBGL_debug_renderer_info`)、AudioContext、字体(`queryLocalFonts` 仅 Chromium / 老法测量)、 `navigator/screen/Intl`、Client Hints(仅 Chromium)、WebRTC IP(公网仍泄露,本地被 mDNS `.local` 掩盖)、ClientRects、mediaDevices、Geolocation(需授权)。

● **必须后端:**真实公网 IP + PTR + ASN/whois + geo + 代理/VPN 判定;HTTP 头原始顺序 + 实际到达的 Client Hints;**TLS 指纹 JA3/JA3N/JA4**(需原始 ClientHello,普通 TLS 卸载后的应用服务器看不到 → `utls` /`fingerproxy` 或抓包);**HTTP/2 Akamai 指纹**(读 `SETTINGS/WINDOW_UPDATE/PRIORITY` 帧);**DNS leak**(自建权威通配 DNS,最难);**TCP/IP OS 指纹 p0f**(抓 SYN 包,需 `CAP_NET_RAW` ,最难)。

1.4 推荐技术栈(别从零写)

- **前端信号:**`FingerprintJS`(MIT, ~42 entropy 源)或 `CreepJS`(MIT,覆盖面最接近,带 spoof 检测)。两者都不含 WebRTC/DNS 泄露,要自己补。
- **TLS/HTTP2 指纹:**`TrackMe`(GPL-3.0, `tls.peet.ws` 引擎,Docker, `/api/all` 吐 JSON)或 `fingerproxy`(注入 `x-JA3/X-JA4/X-HTTP2-Fingerprint` 头);算法本体 `FoxIO-LLC/ja4`(base JA4 = BSD-3,JA4+ = 受限 FoxIO License 1.1)。
- **IP 情报:** `ip-api.com` (免费无 key,含 proxy/hosting/mobile,无 HTTPS,45 req/min,禁商用)/ `ipinfo Lite`(免费仅国家+ASN)/ `IPQualityScore`(欺诈评分最全,付费)/ `MaxMind GeoLite2`(可离线自托管)。

1.5 统一返回 JSON 结构(示例)

```
{
  "ip": {
    "v4": "1.2.3.4", "ptr": "...", "asn": "AS13335", "org": "...",
    "geo": { "country": "US", "city": "...", "proxy": false, "vpn": false, "tor": false },
    "http": { "headers_in_order": [{ "name": "...", "value": "..."}], "client_hints": {} },
    "tls": { "ja3_hash": "...", "ja3n_hash": "...", "ja4": "t13d1516h2_...", "akamai_h2": "1:65536;..." },
    "client": {
      "canvas": "<hash>", "audio": "<hash>",
      "webgl": { "vendor": "...", "renderer": "ANGLE (NVIDIA ...)", "hash": "..." },
      "fonts": ["Arial", "..."],
      "webrtc": { "public_ip": "1.2.3.4", "local": ".local" },
      "navigator": { "ua": "...", "languages": ["zh-CN"], "tz": "Asia/Shanghai",
        "hardwareConcurrency": 16, "deviceMemory": 8 },
      "screen": { "w": 2560, "h": 1440, "dpr": 1.5 }
    }
  }
}
```

1.6 注意

- 合规:指纹采集多数算个人数据(GDPR/CCPA),需告知;爬 browserleaks 遵守 60s crawl-delay。
- 浏览器防护在弱化数据:Safari 26 默认给 canvas/WebGL/audio 注噪声、Brave farbling、Chrome 冻结 UA、WebRTC 本地 IP 被 mDNS 掩盖 → 指纹未必稳定,采集端要多次采样/容噪。

2. 自带风控策略的 web 端检测服务(四类横评)

评判核心:必须自带内置风控逻辑、产出决策/评分(开箱即用),而非只给原始信号。

2.1 海外反欺诈 SaaS(业务决策引擎 + JS SDK)

推荐星级 = 贴合「自带风控策略 + web 端 JS」程度 + 可及性(免费档/定价透明/自助接入)。score-only 因不完全满足会扣分。

推荐	厂商	官网	内置策略	输出	免费档 / 定价	备注
★★★★	SEON	https://seon.io	预置规则 + 自定义 + ML	APPROVE/REV IEW/DECLINE + 分	永久免费(~10规则/500检/月);Starter \$699/mo	最均衡、定价透明、有真免费档,业务反欺诈
★★★★ ½	Castle	https://castle.io	30+预置风险模型+策略引擎	ALLOW/CHALLENGE/DENY	免费 1K calls;Pro \$200/mo	开发者友好,账号安全(登录/注册/ATO/bot)
★★★★	Sift	https://sift.com	Score + Workflows 决策	自动 block/accept/review	企业报价,无免费	产品强,只走企业销售
★★★★	Sardine	https://www.sardine.ai	no-code 规则引擎	approve/decline/review	企业 ~\$15k–254k/yr,无自助	fintech/AML 向,贵
★★★★	IPQS	https://www.ipqualityscore.com	score-only	fraud_score + 标签	免费 1000/月	最便宜,要自己定阈值
★★★★ ½	Fingerprint	https://fingerprint.com	score-only(Suspect Score)	visitorId + 信号 + 分	免费 1K calls	设备识别最强,官方建议别直接判决
★★★★	Riskified / Forter	https://www.riskified.com / https://www.forter.com	托管黑盒	approve/decline + 拒付兜底	按效果付费,无免费	仅电商支付,策略你改不了
★★★★	Stripe Radar	https://stripe.com/radar	ML自动拦截 + 可编辑规则	拦截/放行/复核/3DS	走 Stripe 基本免费	仅对走 Stripe 的支付有效

2.2 边缘 / WAF Bot 管理(托管规则集,流量过代理即生效)

厂商	内置策略	输出	计费	备注
AWS WAF Bot Control	托管规则组	标签 + block/challenge/CAPTCHA	\$10/mo/ACL + Common \$1/M(含 10M 免费)	重度 AWS 最顺、最便宜、有真免费额度
Cloudflare Bot Mgmt + Turnstile	托管规则集	1-99 bot 分	免费档只挡明显 bot;分值+自定义规则要 Enterprise	Turnstile 免费 pass/fail
DataDome	托管 ML 全决策	allow/block/challenge(~2ms)	第三方估 ~\$3.8k+/mo	真 turnkey
HUMAN / Kasada / Arkose	托管 ML 决策	判定 + 强制处置	企业报价	Arkose 偏验证挑战
Akamai Bot Manager	托管 3000+签名	0-100 分 + 预置响应	企业,需 Akamai CDN	
Imperva / Radware	托管分类+处置	human/good/bad-bot	企业,可 partial 私有化	虚拟设备/本地
hCaptcha	免费仅 pass/fail	风险分+规则引擎要 Enterprise	Pro \$99/mo	

2.3 国内风控厂商(自带策略模板 + JS 验证码 + 设备指纹,多数可私有化)

厂商	内置策略	Web 集成	私有化	备注
同盾·天策	full,"专业化策略规则模板"+全生命周期	设备指纹SDK + 决策 API	可私有化	策略深度最强,Web 验证码弱
顶象·CTU	full,三态 ACCEPT/REVIEW/REJECT	设备指纹 + 第五代验证码(JS)	主打快速私有化	四项最齐
腾讯天御 + RCP 中台	full,决策流/评分卡/决策表/ML+场景模板	验证码(JS)成熟 + API	RCP 很可能可私有化	天御 SaaS 按量+免费版
阿里云·风险识别	full,"上千套策略模型即开即用",返回 score+tags+finalDecision	设备SDK + 决策API + 独立验证码	云上私有化(独享/私域,非纯本地)	你们在 AWS 不在阿里云需权衡
数美·天网	full,自带持续更新策略体系	设备SDK + 智能验证码 + API	可多云/私有部署	黑产对抗情报强
网易易盾	full,风控引擎+300+规则库+验证码策略自动升级	行为验证码(招牌) + 设备指纹	partial	验证码业界标杆
极验 GeeTest	偏 score-only,引擎需自配规则	行为验证码 + 设备指纹(最多45类标签)	partial	自带成熟策略库较弱
瑞数·Botgate	managed,边缘动态安全	网关注入动态JS	可本地化	反自动化强,业务决策弱

2.4 开源可自托管(自带内置策略,零授权费)

项目	内置策略	形态 / 输出	许可	备注
CrowdSec	100+ 预置行为场景 + Hub + 免费众包 CTI	读日志 → ban/captcha/throttle,bouncer 执行	MIT	最强自托管全决策;非 JS,日志/行为驱动
OWASP Coraza + CRS	OWASP Top Ten 托管规则集,默认阻断+异常评分	反代/边缘插件 (Caddy/Traefik/Envoy)→ allow/deny	Apache-2.0	最新 v4.27.0
fail2ban	内置 jails/filters(默认禁用需开)	日志 → 封 IP	GPLv2 +	活跃维护但最后 tag 1.1.0(2024-04)
FingerprintJS BotD	score-only verdict	客户端 JS,出 detected + botKind	MIT	开源版覆盖有限(AI agent/反检测浏览器要付费 Pro)
✗ Drools / GoRules ZEN / Camunda DMN	空引擎,无内置策略	自己写规则+喂信号	OSS	想"自带策略"别选这类

2.5 选型决策指引

- 贴 JS 就出决策 + 有免费档 + 定价透明 → **SEON**(业务反欺诈)/ **Castle**(账号安全)。
- 重度 AWS、只挡 bot/爬虫、最便宜 turnkey → **AWS WAF Bot Control**。
- 边缘托管、流量过代理即拦 → DataDome / Cloudflare。
- 国内业务 + 私有化 + 自带策略模板 → **顶象** / **腾讯天御 RCP** / **同盾**。
- 自托管、零授权费、自带内置策略 → **CrowdSec**(IP/行为)+ **Coraza+CRS**(Web 攻击)。
- 仅支付且走 Stripe → Radar 几乎免费。

3. 自建 payment checkout 前置风控选型 → 首选 SEON

前提:面向海外/全球、自建多通道收单、想自己掌控风控逻辑。三点若变见 §3.2。

3.1 为什么是 SEON

1. 输出形态即"前置风控"所需:Fraud API 实时返回 APPROVE / REVIEW / DECLINE + 分 + 命中规则,正好卡在 authorize 之前 → DECLINE 拒付 / REVIEW 触发 3DS-OTP·人工 / APPROVE 放行。
2. **PSP 无关,不锁收单通道**(对自建/多通道是决定性的):只吃交易元数据 + 客户/设备信号,与谁收单解耦;对比 Stripe Radar 只能服务走 Stripe 的支付。
3. **数据增强(digital footprint)打在 CNP 欺诈命门**:邮箱/手机/IP 反查数字足迹 + 设备指纹 + 代理/VPN,识别盗卡/养号/一人多账户。
4. **既开箱有策略,又能改规则**:SEON 专家预置规则 + ML + 自定义规则 + 名单,契合"自建但不想从零写"。
5. **接入轻、契合 AWS/Lambda 同步前置校验**:checkout 页 JS SDK 采集 → 后端一次同步调 API 拿决策,亚秒级。
6. **可及性最好**:永久免费档 + 定价透明(\$699/mo Starter),先 PoC 跑真实流量再上量。

7. **PCI scope 友好**:走交易元数据 + 设备信号,不碰 PAN(或只收 token)。

3.2 什么情况换别家

真实诉求	换成	原因
把欺诈+拒付责任整体外包,不在乎自己写规则	Riskified / Forter	自带拒付兜底,专为支付 checkout 预审;但黑盒、企业合同、按成交额抽成,失去规则控制权
已/将全量走 Stripe 收单	Stripe Radar	ML+可编辑规则,走 Stripe 基本免费;仅服务 Stripe
超大体量 + 企业预算,支付滥用 +ATO 一体	Sift / Sardine	Sardine 偏 fintech/AML 且贵
面向国内用户的支付	同盾天策 / 腾讯天御 / 顶象	中文支持、本地黑产数据、可私有化
极致省钱、愿自建决策	IPQS/Fingerprint 信号 + 自研规则引擎	最便宜,但不满足"自带策略"

一句话:Riskified/Forter 比 SEON 更"专做支付 checkout",但它替你决定;SEON 让你自己做决定还做得省心。你要"自建前置风控",选让你掌控的那个。

3.3 落地形态(SEON 版)

checkout 页:SEON JS SDK 采集设备/行为 → 生成加密 session
↓ 用户点"支付"
后端 Lambda(扣款前):调 SEON Fraud API
入参:金额 / 邮箱 / 手机 / IP / BIN / 设备 session / userId
↓
DECLINE → 拒付 + 记风险事件
REVIEW → 触发 3DS / OTP / 转人工队列
APPROVE → 放行到收单
策略:先用预置规则 + 阈值跑灰度,再按拒付/误杀数据调规则权重

4. 价格对比(支付 checkout 前置风控相关)

假设:1 万笔 checkout/月,客单价 \$100 → 月 GMV \$1M。⊕=本会话已核公开价;≈=指示性需报价。

厂商	计价模型	单价	免费档	1万笔/月 估算	重复验证额外计费?
SEON	按 check	⊕ Starter \$699/2,500检 ≈ \$0.28/检; 上量按量谈	⊕ 500 检/月	≈ \$2,800/月 (Premium 更低)	是,逐笔调=逐笔付
IPQS	按 lookup	⊕ Startup \$99/5,000 ≈ \$0.02/次	⊕ 1,000/ 月	≈ \$200-500/月	是(单价极低)
Fingerprint	按 API call	⊕ Pro Plus \$99/20,000,超 \$4/千	⊕ 1,000/ 月	≈ \$99/月	是(单价最低)
Stripe Radar	按笔交易	⊕ \$0.05/笔,走 Stripe 标准价则免除; Fraud Teams + \$0.02 / \$0.07	含在 Stripe	≈ \$0(标准价)~ \$700(Fraud Teams)	否(重复几乎免费)
Riskified / Forter	按通过订单 GMV 抽成(含拒付兜底)	≈ GMV 零点几个百分点(无公开费率,指示性)	无	≈ \$3,000/月(含拒付赔付)	否(本就逐单)
Sardine	企业年单	≈ \$15k-254k/yr(中位 ~\$95k)	无	≈ \$8,000/月 量级	否
Sift	企业 custom	无公开价	无	数千刀/月起	否

读表关键:看"模型"不看单价。 - 按次/按笔(SEON/IPQS/Fingerprint):成本随交易笔数走,与独立用户数无关 → 反复验证同一用户会线性累加。 - 按 GMV 抽成 / 企业套餐(Riskified/Forter/Sardine/Sift):重复评估不额外计费;代价是贵 + 不透明 + 交出控制权(前两家还接走拒付责任)。 - Stripe Radar:走标准收单价基本免费且随便重复,但锁 Stripe。 - ⚠️ GMV 抽成看着和 SEON 差不多(\$3k vs \$2.8k),但它**含拒付赔付**,不同口径;SEON 之外拒付损失仍由你承担。

5. 同一用户是否需要反复重复验证?

结论:风险评分要逐笔做;用户可见的验证不要反复打扰。两件事必须拆开。

- 后端风险评分:每笔交易都要重新评(必须)。** 风险是"交易级"而非"用户级": - 账号被盗(ATO):曾经良性 ≠ 这笔安全; - 盗卡/换卡/换收货地/换设备/换 IP:每笔都可能变; - Velocity 规则(10 分钟 5 张卡)只有逐笔喂事件才算得出。 - 一次评分 \$0.02-0.28,一次拒付却是货损 + \$15-100 罚金 + 拒付率惩罚 → **别为省 API 费漏评。**
- 用户可见验证(3DS/OTP/验证码):对已知良性用户不要反复弹。** 用风险自适应(adaptive auth): - 设备指纹 / visitorId 持久识别返客; - 维护 trust list:对 (user + device + 卡) 良性组合缓存"信任态",设 TTL(7-30 天); - 只在异常时升级:新设备 / 新卡 / 大额 / velocity 命中 / 评分跨阈值才弹,其余静默放行。
- 成本 × 重复 怎么调和(以 SEON 为例):** - 把"打分"和"加摩擦"分开:后端逐笔打分照做,前台 step-up 按风险选择性触发; - 对极低风险的重复事件(同 user+device+小额、TTL 内、信任态命中)走本地缓存/信任态短路,减少调用(省的是"摩擦"和部分调用,不是"风险判断"); - 按复购频率反选计价模型:
 - 高频重复小额(订阅 / 游戏充值):按次计费会被复购量放大 → Stripe Radar(若用 Stripe)或 GMV 抽成模型更划算,或 SEON + 重度信任缓存;
 - 低频高额:按次计费(SEON)完全 OK,单笔成本可忽略。

你的优先级	选
自建多通道、要掌控规则、可接受逐笔付费	SEON(逐笔评分 + 信任态缓存控复购成本)
已用/将用 Stripe,且复购频繁	Stripe Radar(重复几乎免费)
只想把欺诈+拒付整体外包	Riskified / Forter(GMV 抽成含兜底)
极致省钱、愿自建决策	IPQS/Fingerprint 信号 + 自研规则 + 自建 trust list

6. 关键来源链接

指纹/JSON - <https://tls.browserleaks.com/json> · <https://browserleaks.com/tls> · <https://browserleaks.com/robots.txt> - <https://github.com/fingerprintjs/fingerprintjs> · <https://github.com/abrahamjuliot/creepjs> - <https://github.com/wwhtrbtt/TrackMe> · <https://github.com/wi1dcard/fingerproxy> · <https://github.com/FoxIO-LLC/ja4>

反欺诈 SaaS - SEON <https://seon.io/pricing/> · <https://docs.seon.io/api-reference/fraud-api> - Castle <https://castle.io/pricing/> · Sift <https://sift.com/platform/> · Sardine <https://www.sardine.ai/rules-engine> - IPQS <https://www.ipqualityscore.com/plans> · Fingerprint <https://fingerprint.com/pricing/> - Riskified <https://www.riskified.com/chargeback-guarantee/> · Forter <https://www.forter.com/platform/fraud-management/> - Stripe Radar <https://stripe.com/radar/pricing>

边缘 Bot 管理 - AWS WAF Bot Control <https://aws.amazon.com/waf/pricing/> · Cloudflare <https://developers.cloudflare.com/bots/> - DataDome <https://datadome.co/products/bot-protection/> · Akamai <https://www.akamai.com/products/bot-manager>

国内风控 - 同盾 <https://www.tongdun.cn/product/merchants> · 顶象 <https://www.dingxiang-inc.com/docs/detail/ctu> - 腾讯天御 RCP <https://cloud.tencent.com/product/rcp> · 阿里云风险识别 <https://help.aliyun.com/zh/fraud-detection/> - 数美 <https://www.ishumei.com> · 网易易盾 <https://dun.163.com> · 极验 <https://www.geetest.com>

开源自托管 - CrowdSec <https://github.com/crowdsecurity/crowdsec> · Coraza <https://github.com/corazawaf/coraza> · OWASP CRS <https://coreruleset.org> - BotD <https://github.com/fingerprintjs/BotD> · fail2ban <https://github.com/fail2ban/fail2ban>

7. 相关记忆(背景上下文)

以下为本人持久记忆中与"风控 / 支付 / 真结算"相关的条目摘要(已排除含凭据的记忆;全文在 `~/claude/.../memory/`)。它们解释了本会话选型建议的背景假设:重度 AWS/Lambda、自建多通道收单、含真实结算的游戏充值(→ 高频重复验证 → 对计价模型敏感)。

- **rocket-nano 风控 invoke 配置错** — production2 `scp.yaml1` 指向 riskadmin 应为 risk(:live);风控走 Lambda reqresp 调用。

- **rocket-nano KYC 在线生效调研** — fixResult 会话缓存 Verified 遮罩 + KYCReset settle 跨 Pod 滞留;推荐 lazy-reconcile SN 方案。说明已有"KYC/身份核验"链路,前置风控可与之衔接。
- **scp payin 三 Tunnel 拆分** — payin=service(/api/payin/v1/invoke), payincallback=wire(回调)、payinadmin=service。→ **多通道收单 = PSP 无关风控的现实依据**(对应 §3.1 第 2 点)。
- **scp riskadmin lambda** — riskadmin 拆分 + Mongo URI/CA/DocumentDB code 等修复;风控后台在 Lambda 上。
- **scp-lambda risk 预置并发+内存** — 风控 Lambda 512MB + 预置并发,reqresp 事件契约 {path,payload}。→ 前置风控同步调用的运行时形态。
- **slots-relay 受控倍率老虎机中转** — 面向真玩家(**真结算**)+ 倍率受控,经 Lambda reqresp。→ **真实结算 + 高频充值场景**,正是 §5 "重复验证成本"最敏感的业务。
- **slots-relay RTP+口味设计** — RTP 开环指数倾斜 + 物化 PMF(DynamoDB 权威 + S3 + 内存)。

导出完毕。如需:① 把 §3.3 落地为 Go/Node 的 Lambda 中间件骨架(含三态分支 + trust list 缓存 + 超时降级);② 补充其它厂商官网/星级;③ 把"全量打分 + 选择性 step-up + 信任态缓存"画成流程图 —— 告知即可。